

AHS Vault — UK Enterprise-Ready

PDF 2 of 2: Needs Sign / Money / Fee / Permission / Government Process

B2B SaaS | You-host relay + BYO Drive | Finance + NHS + Gov | UK Ltd exists | Date: 2026-09-11

This PDF is ONLY the work that needs **an external signature, payment, or government/auditor process**. Nothing here can be finished by editing code alone. For each: **why it blocks a UK sale + who asks, authority/portal, indicative fee (check live price), steps, prerequisites from PDF 1, lead time, validity, evidence to file**. Fees are **indicative UK 2026 bands** — confirm on the linked portal before budgeting.

Assumption: PDF 1 done (secrets rotated, TLS on, CORS locked, authZ enforced, keys encrypted, IMAP opt-in, SBOM/scans committed). Booking audits before that = fail + pay twice.

1	Companies House pack (download, no fee if current)	COMPANY — no sign, £0 if filed
Why / who: Why/ask: vendor setup + MSA signing + KYC (procurement, G-Cloud, banks).		
Where: Authority: find-and-update.company-information.service.gov.uk.		
Cost: Fee: £0 downloads; late-filing penalties separate. Yearly confirmation statement fee applies.		
How: Steps: download Incorp Cert + Confirmation Statement + PSC → board minute authorising product + processing → file legal/COMPANY/.		
Need from PDF1: Ltd name/no. for LICENSE/NOTICE. Time: same day. Keep yearly.		
2	IP Assignments (needs wet/e-signatures)	SIGN — £0 + solicitor review optional
Why / who: Why/ask: prove Ltd owns Rust/Go/React/Kotlin code (legal, investors, ISO).		
Where: Authority: counterparties (every committer from git log) + solicitor template.		
Cost: Fee: £0 self-serve; £500-1.5k if solicitor drafts/reviews.		
How: Steps: list committers → each signs assignment + moral-rights waiver (past+future) → legal/IP/ + fix Cargo/package licence fields.		
Time: 1-2 wks chasing. Keep per contributor.		
3	UKIPO Trademark (permission process)	GOVT PERMISSION — fee + exam + opposition
Why / who: Why/ask: brand ownership for stores + enterprise trust + disputes.		
Where: Authority: trademarks.service.gov.uk, classes 9/38/42.		
Cost: Fee (indicative): ~£170 first class + ~£50 each extra; solicitor extra if opposed.		
How: Steps: search → apply → examiner → 2-mo opposition → registration → TM symbol + watch.		
Need: Ltd owner details. Time: 3-4 mo clean. Valid 10 yrs.		
4	HMRC VAT + Corp Tax (permission/registration)	GOVT — free, wait
Why / who: Why/ask: B2B invoices + AP payment (customer finance).		
Where: Authority: HMRC via Government Gateway (VAT threshold £90k or voluntary).		
Cost: Fee: £0. Penalties if late.		
How: Steps: register VAT → receive number → put on Order Form/invoices; note UTR. Save finance/.		
Time: 1-4 wks.		
5	PI (£2-5M) + Cyber Insurance (paid certs)	MONEY — yearly premium
Why / who: Why/ask: RFP mandatory pass/fail (procurement).		
Where: Authority: tech broker/insurer. Must disclose: SaaS vault, crypto, biometrics, BYO Drive, IMAP shield, UK hosting.		
Cost: Fee (indicative): PI £500-3k/yr + cyber £800-5k/yr SME, by revenue/limits.		
How: Steps: proposal → wording aligned to MSA cap/SLA → certs to legal/INSURANCE/ + CISO pack.		
Need: MSA/SLA drafts + arch/DFD. Valid yearly.		
6	EULA + MSA/Order + SLA + Use Policy (needs solicitor SIGN)	SIGN + FEE — legal review

Why / who: Why/ask: otherwise B2B licence/liability/termination/audit/exit unenforceable (legal, banks).

Where: Authority: your solicitor (England & Wales law).

Cost: Fee (indicative): £2k-8k pack + per-deal tweaks.

How: Steps: solicitor reviews PDF-1 drafts (scope: relay + BYO Drive, per-seat, 99.9% SLA+credits, mnemonic/Drive duties, cap, audit + return-delete) → sign MSA+Order per customer → publish EULA/Use.

Need: hosting model + ICO no. + insurance limits. Time: 2-4 wks.

7	EV Code Signing + Apple + Play + public TLS (paid trust)	MONEY + VETTING — CA/Apple/Google
---	--	-----------------------------------

Why / who: Why/ask: SmartScreen/notarization/Play + https/HSTS; updater key leaked so rotation mandatory.

Where: Authority: EV CA (USB/HSM) + Apple Developer + Google Play + public CA (DigiCert/LE).

Cost: Fee (indicative): EV £200-500/yr + Apple £79/yr + Play £25 once + TLS £0 (LE) - £200/yr.

How: Steps: EV vetting → sign exe/msi in CI via Secrets (new pubkey to tauri.conf) → notarize → Play signing + Data Safety + Play DPA → TLS + HSTS + owned domain SPF/DKIM/DMARC; purge old key history.

Need PDF1 B1+B10. Time: EV 1-3 wks; rest days.

8	ICO Controller Registration (fee + number)	GOVT FEE — ICO
---	--	----------------

Why / who: Why/ask: legal duty; buyers check register + demand number in Notice/DPA (all B2B, NHS).

Where: Authority: ico.org.uk/register.

Cost: Fee (indicative): £40-60 SME tiers; up to £2.9k large. Yearly direct debit.

How: Steps: register → publish number in Notice/DPA/footer → renew yearly.

Time: 1-7 days.

9	Privacy finals: Notice + DPA + ROPA + DPIA + LIA + TRA/IDTA (needs DPO SIGN)	SIGN — DPO + solicitor
---	--	------------------------

Why / who: Why/ask: DPIA mandatory for biometrics/vault/mail-scan (Art.35); no signed DPA/IDTA = no lawful US transfer (Google/GitHub/Fonts); NHS IG rejects without.

Where: Authority: DPO (internal or DPO-as-service) + solicitor + ICO templates (IDTA).

Cost: Fee (indicative): DPO-as-service £500-2k/mo; solicitor £1.5k-5k pack.

How: Steps: DPO signs PDF-1 drafts AFTER fixes (IMAP opt-in+minimise+redact, encrypted storage, redacted logs, fonts self-hosted, eu-west-2 hosting) → sign customer DPA + sub-DPAs → TRA+IDTA per US flow → file legal/PRIVACY/.

Time: 2-6 wks post-fix. Review yearly/on change.

10	Retention/DSAR/Breach ops + DPO letter (needs operation + sign)	SIGN + OPS — DPO
----	---	------------------

Why / who: Why/ask: buyers test deletion (DB+Drive purge) + DSAR month + 72h breach law.

Where: Authority: DPO + ops runbooks.

Cost: Fee: within DPO cover; tooling minimal.

How: Steps: implement retention table → DSAR intake/verify/search-by-PK/redact/respond/log + drill → breach detect-contain-assess-notify-ICO72h → DPO appointment letter → log drills.

Need: db.go schema + gdrive Delete/Get evidence. Time: 2-4 wks to live.

11	Cyber Essentials (assessor fee)	FEE + ASSESS — IASME
----	---------------------------------	----------------------

Why / who: Why/ask: minimum for any gov deal; baseline all RFPs.

Where: Authority: IASME portal + assessor.

Cost: Fee (indicative): ~£300-600 + remediation.

How: Steps: self-assess (firewalls, config, patch, accounts, malware for relay/PG/CI/laptops) → submit → fix fails.

Need PDF1 B2+B3+B10 + patch evidence. Time: 1-4 wks. Valid 12 mo.

12	Cyber Essentials Plus (audited, higher fee)	FEE + AUDIT — IASME Plus auditor
----	---	----------------------------------

Why / who: Why/ask: audited proof for NHS/gov sensitive + finance de-facto.

Where: Authority: licensed Plus auditor (remote/on-site build+malware+network).

Cost: Fee (indicative): ~£1.5k-3.5k SME + retest.

How: Steps: pass CE → book audit (desktop/backend/mobile samples) → remediate → cert to CISO pack.

Need: TLS, signed builds, MDM. **Time:** 1-3 mo. **Valid** 12 mo.

13	ISO 27001 (+SoA) + 27701 (UKAS audit fee)	FEE + AUDIT — UKAS auditor
----	---	----------------------------

Why / who: Why/ask: must-have scored item for finance/gov; proves ISMS.

Where: Authority: UKAS-accredited cert body, Stage1 docs + Stage2 practice.

Cost: Fee (indicative): £8k-25k SME cert + yearly surveillance; 27701 uplift extra.

How: Steps: scope ISMS → SoA+risk+policies+evidence (PDF-1 docs/scans/logs/reviews) → Stage1 → Stage2 → cert + 3-yr cycle.

Time: 3-9 mo. **Keep surveillance yearly.**

14	SOC 2 Type II (CPA audit fee, NDA-only report)	FEE + AUDIT — CPA firm
----	--	------------------------

Why / who: Why/ask: banks/US buyers expect alongside ISO.

Where: Authority: licensed CPA (Trust: Security/Availability/Confidentiality).

Cost: Fee (indicative): Type I £10k-25k; Type II £20k-60k SME.

How: Steps: Type I design → 3-12 mo observation (changes, access reviews, backups, IR drills) → report UNDER NDA.

Time: 6-15 mo total. **Valid** 12 mo.

15	PSTI Statement of Compliance (signed declaration)	SIGN — self-declare, Trading Standards enforced
----	---	---

Why / who: Why/ask: offence to sell consumer-connectable apps without SoC + CVD + support period.

Where: Authority: self (manufacturer) published with product/website; enforced by Trading Standards.

Cost: Fee: £0 (after fixes).

How: Steps: confirm no defaults + CVD in SECURITY.md + support window → publish signed SoC per release → keep updater signed.

Need PDF1 B1+B10. **Time:** days post-fix.

16	NHS DSPT (free portal, effort + sign-off)	GOVT PERMISSION — NHS England
----	---	-------------------------------

Why / who: Why/ask: mandatory to hold NHS data; no assessed DSPT = no pilot.

Where: Authority: DSPT portal, annual.

Cost: Fee: £0; effort + evidence (CE+, ISO/SoA, DPIA/ROPA/DPA, training, backup/IR).

How: Steps: register org → upload evidence → publish assessed status → renew yearly.

Time: 1-3 mo after base certs.

17	NHS DTAC (free workbook, Trust sign-off)	GOVT PERMISSION — Trust assessors
----	--	-----------------------------------

Why / who: Why/ask: mandatory NHS tech gate (safety/technical/interop/usability/access).

Where: Authority: deploying Trust.

Cost: Fee: £0; effort heavy.

How: Steps: workbook with arch/DFD, pen test, AA, UAT, BCP/DR, UK hosting, exit plan → Trust review per deployment.

Time: 1-2 mo when evidence ready.

18	DCB0120/0160 + CSO + Safety Case (paid effort/sign)	SIGN + FEE — CSO time
----	---	-----------------------

Why / who: Why/ask: required if vault touches care pathways.

Where: Authority: appointed Clinical Safety Officer; joint manufacturer/deployer case.

Cost: Fee (indicative): CSO £5k-20k+ effort (employed/contract).

How: Steps: CSO → hazard log + mitigations + Safety Case per release → sign-off.

Time: 1-3 mo. **Maintain per release.**

19	G-Cloud listing (free, windowed)	GOVT SALES — CCS
----	----------------------------------	------------------

Why / who: Why/ask: compliant route for gov/NHS to buy SaaS without tender.

Where: Authority: Crown Commercial Service, periodic rounds.

Cost: Fee: £0.

How: Steps: await round → submit service+pricing+terms+security (reuse CAIQ/CE+/ISO/DSPT) → maintain + call-offs.

Time: per timetable (weeks).

20	Export control record (ECJU permission if controlled)	GOVT — ECJU/SPIRE
----	---	-------------------

Why / who: Why/ask: AES-256 distribution outside UK may need licence record.

Where: Authority: ECJU; OGEL/licence on SPIRE if controlled (mass-market often exempt — record rationale).

Cost: Fee: £0.

How: Steps: classify 5A002/5D002 → record or apply → screen territories → file.

Time: days (weeks if licence).

21	WCAG 2.2 AA audit + Statement (paid audit)	FEE + AUDIT — DAC-style auditor
----	--	---------------------------------

Why / who: Why/ask: Equality Act + Public Sector Regs block gov/NHS without AA.

Where: Authority: external auditor (JAWS/NVDA/VoiceOver, keyboard, contrast).

Cost: Fee (indicative): £2k-8k + fixes/retest.

How: Steps: audit desktop/web/mobile → fix → publish statement (scope/contacts/review).

Time: 2-6 wks.

22	CREST/CHECK Pen Test + Crypto Audit (paid, yearly)	FEE — CREST/TIGER + crypto firm
----	--	---------------------------------

Why / who: Why/ask: only independent test buyers trust; exec summary <12 mo + retest letter is the actual sales doc.

Where: Authority: CREST/CHECK/TIGER + NCC/Cure53-style crypto reviewers; scope: relay/API (ASVS L2), desktop (binary/updater/FUSE/WebDAV), mobile (MASVS), WS/rate-limit; crypto: KDF/nonce/wire/WebAuthn/BIP-39.

Cost: Fee (indicative): pen test £5k-20k; crypto £10k-40k; retests extra.

How: Steps: raise coverage+E2E → test → fix criticals → paid retest → share exec summary; full report NDA.

Need PDF1 B2-B6. Time: 2-4 wks + fixes. Repeat yearly.

23	Load/Soak + TLS scans + DR drills + AA/UAT/Clinical/DSAR logs (effort + some fee)	FEE/EFFORT — ops + users + CSO/DPO
----	---	------------------------------------

Why / who: Why/ask: SLA RPO/RTO + resilience + usability + IG each need logged proof.

Where: Authority: k6/SSL Labs (free tools) + ops + finance/NHS users + CSO + DPO; AA auditor paid above.

Cost: Fee: mostly effort; AA/crypto/pen test fees already counted.

How: Steps: k6 + HSTS scan → pg PITR + restore timing + failover log → UAT sign → Safety sign (if health) → DSAR drill + DB+Drive deletion proof → file evidence/.

Time: 2-6 wks; quarterly/ per-release after.

Order that wastes least money

- 1. **Company + HMRC + ICO + IP chase** — days, unlocks vendor setup.
- 2. **Insurances + solicitor pack + DPO** — parallel, unlocks signing.
- 3. **EV/TLS/stores rotation** — trust for releases.
- 4. **CE then CE+** — only after PDF-1 verified.
- 5. **Pen test + crypto audit** — after fixes; keep exec summary.
- 6. **ISO + SOC 2 + PSTI + AA + export** — start ISMS early (months).
- 7. **DSPT + DTAC (+Safety if clinical) + G-Cloud** — needs all above.
- 8. **Commercial pack per deal (NDA → certs → DPA → pilot SOW → exit plan).**